

## Next iteration: attacks under reduced attacker knowledge

Gray-box (unknown coefficient) and black-box (unknown algorithm) tiers — both anchored on the coefficient- and algorithm-agnostic ruler  $c(x)$

### SPARK goal-insertion notes

## The idea in one line

The attacker’s targeting function is the control-authority ruler  $c(x)$  (more precisely the worst-blend authority  $C(x) = \min_y c_y(x)$ ), and **it is a physical property of the robot-plus-obstacle, not of the safety algorithm or its tuning**. So attacks survive as we peel away attacker knowledge — first the demand *coefficient* ( $\eta/\lambda$ ), then the *algorithm* itself — with only a graceful degradation in how surgical the attack is. The robot’s own failure (give-up / collision / freeze) is the oracle throughout.

## The three tiers

| tier             | attacker knows                                                                   | objective                                                                            | oracle                                          |
|------------------|----------------------------------------------------------------------------------|--------------------------------------------------------------------------------------|-------------------------------------------------|
| white-box        | algorithm + coefficient                                                          | compute<br>$g(x) = C(x) - d(x)$ ,<br>drive $g < 0$                                   | predicted                                       |
| <b>gray-box</b>  | algorithm, <b>not</b><br>coefficient                                             | minimize $C(x)$<br>(coefficient-free)                                                | behavioral give-up                              |
| <b>black-box</b> | <i>neither</i> — only that it<br>is a <b>myopic</b><br><b>value-based</b> filter | minimize $C(x)$ <b>and</b><br>maximize<br>depth/closing (hedge<br>over demand shape) | give-up <b>or</b> collision <b>or</b><br>freeze |

The current harness assumes white-box (it scores candidates against a known  $\eta$ /known  $g(x)$ ). The next iteration drops that assumption in two stages.

## Why the coefficient and the algorithm both drop out

Recall the split (docs/cx\_derivation.pdf, docs/cx\_policies.pdf):

- **Supply side** —  $c(x) = \sum_k u_{\text{lim},k} |[n^\top J(x)G(x)]_k|$  — depends only on **actuator limits, kinematics ( $J$ ), and safety-index geometry (the contact normal  $n$ )**. No  $\eta$ , no  $\lambda$ , and no choice of algorithm: every value-based controller reads the *same* ruler.

- **Demand side** —  $d = \eta$  (constant) or  $d = \lambda\phi$  (proportional) — is the *only* place the coefficient lives, and the choice of demand *shape* is the only place the algorithm family shows up.

$C(x)$  is *literally identical* across algorithms that share a safety index (SPARK’s value-based family can), because it measures **how fast the actuators can retreat from the obstacle** — pure physics. For different-but-distance-based indices it shifts slightly (the higher-order velocity term perturbs  $n$ ) but stays the same retreat-authority quantity, since the dominant escape direction is the contact normal for any collision index.

---

## Tier 1 — gray-box: know the algorithm, not the coefficient

**Objective is coefficient-free.** The fuzz objective

$$\min_{G'_1} \min_{\text{admissible}} \min_t C(x_t)$$

references no  $\eta/\lambda$ . The search is **monotone downward** in  $C$ : smaller is strictly more vulnerable, so we only ever push it down.

**Stopping logic, made exact.** For a single active constraint the test is exact: SSA fails at  $x \iff c(x) < \eta$ . Hence if the reachable floor  $c_{\min}^* := \inf_{\text{reach.}} c(x) \geq \eta$ , no reachable state is infeasible and the attack cannot trigger a give-up.  $c_{\min}^*$  is a property of the **environment + robot alone** — the *attackability threshold*; the attack succeeds iff  $\eta > c_{\min}^*$ , and the unknown  $\eta$  merely decides which side of that floor it sits on.

**Multi-constraint (pincer): use  $C$ , not  $\min_i c_i$ .**  $\min_i c_i \geq \eta$  is necessary but not sufficient under conflict. With constant  $\eta$  the exact test collapses to

$$C(x) := \min_{y \in \Delta} c_y(x) \geq \eta, \quad c_y(x) = \sum_k u_{\text{lim},k} \left| \left( \sum_i y_i L_g \phi_i \right)_k \right|,$$

still coefficient-free, and  $C(x) \leq \min_i c_i(x)$  catches pincers the per-constraint test misses. (Drift: use  $C(x) - L_f \phi(x)$ ;  $L_f \phi$  is coefficient-free too. SPARK is first-order, so  $L_f \phi = 0$ .)

**Oracle: the physical give-up, not a numeric  $\geq \eta$  check.** Since  $\eta$  is unknown we cannot compare to it. Instead we watch: hard QP infeasible  $\rightarrow u_{\text{ref}}$  / collision; soft  $\rightarrow$  slack  $> 0$  (stall or push-through). Observing it proves  $\eta > c$  at that state and hands a lower bound on  $\eta$  for free.

**Scoping.** Cleanliness assumes  $\eta/\lambda$  is the only unknown and the safety index  $\phi$  is **known** (its form fixes  $n$ , hence  $c$ ). If the index-shaping coefficients were also unknown, fall back to purely behavioral fuzzing. In SPARK  $\phi$ ’s form is fixed per algorithm and  $\eta/\lambda$  are the tunable rates, so “unknown rate only” is the realistic gray-box case.

---

## Tier 2 — black-box: don’t even know the algorithm

Here we know only that the robot runs *some* myopic value-based (or heuristic) safe controller.  $C(x)$  still transfers (it is algorithm-agnostic), but two things degrade.

**Loss 1 — the demand *shape* is unknown, so “minimize  $C$ ” alone is not sufficient.** We no longer know whether the demand is **constant** ( $\eta$ , defeated at a *grazing* boundary contact) or **proportional** ( $\lambda\phi$ , whose demand vanishes at the boundary and is only defeated by a *deeply penetrating* contact,  $\phi > c/\lambda$ ). This is exactly the empirical 6–8-seeds (constant) vs 2-seeds (proportional) gap. The robust, still-algorithm-free objective is therefore a **hedge that beats every demand model at once** — steer to states that are simultaneously:

- **low retreat authority** ( $C(x)$  small) — hurts *both* families; and
- **deep / fast-closing** ( $\phi$  large, high closing rate) — additionally hurts the *proportional* family.

“Deep, low-authority, fast-closing contact” is the universal worst case for every value-based filter regardless of demand shape. Reaching the deep case is genuinely harder (a working proportional filter drives  $\phi$  back down, so you must overshoot the recovery shell — why only 2 seeds fell to it), and the black-box attacker, not knowing which target they face, must attempt the harder objective to cover both. Concretely, a scalarization such as  $\min_t (C(x_t) - \kappa \phi(x_t))$  with  $\kappa$  swept over a small grid, or an explicit two-objective (low  $C$ , high  $\phi$ ) frontier.

**Loss 2 — the payload is not predictable, but we don’t need it to be.** Hard filter  $\rightarrow$  **collision** (give-up); relaxed  $\rightarrow$  **denial of service** (freeze) or push-through; heuristic (SMA/PFM)  $\rightarrow$  underbrake. We can’t tell in advance which. It costs nothing: the **behavioral oracle** still fires, and **either outcome is a successful attack** (integrity violation vs. DoS). We simply take whichever payload the unknown algorithm hands us; *some* failure occurs at  $C < d$  for every algorithm in the class.

**Boundary condition — the premise needs a *myopic one-step* filter.** The whole “fails when  $C(x) < d(x)$ ” story assumes a reactive one-step value-based/heuristic filter. A genuinely **predictive / recursively-feasible** filter backed by a real control-invariant set (MPC safety filter, backup-CBF, HJ-reachability backstop) would never *enter* the region where  $C < d$ , so a pointwise- $c(x)$  attack would not bite. So the honest scope is **algorithm-agnostic across the myopic one-step family, not across all conceivable safety layers** — which is consistent with the paper, since that myopic family is exactly what humanoids deploy (the reason the vulnerability exists).

---

## What to build (deltas from the current harness)

1. **Coefficient-free scorer** (both tiers). Add a `min_reachable_authority` objective scoring a candidate by  $\min_t C(x_t)$  (or  $\min_t \min_i c_i(x_t)$  as a cheap first cut), computed from  $J$ ,  $u_{\text{lim}}$ , contact normals — **without** reading  $\eta/\lambda$  or  $g(x)$ . Reuse `authority_policies.py` (`feasibility_margin`, `eval_state`) but split out the  $C$ -only path so no demand term is referenced.
2. **Depth/closing term** (black-box). Add  $\phi(x)$  (penetration) and its closing rate to the objective; expose a scalarization weight  $\kappa$  (grid-swept) or a two-objective frontier, so a single search covers both constant- and proportional-demand targets.
3. **Behavioral oracle** (both tiers). Log the failure event directly — hard-filter QP infeasibility flag / revert-to- $u_{\text{ref}}$ ; soft-filter `action_info["violation"]` / slack  $> 0$ ; classify the outcome as COLLISION vs DEADLOCK — and treat *that*, not a  $g < 0$  comparison, as the success label.
4. **Report the attackability threshold.** Per seed, output  $c_{\min}^* = \min_t C(x_t)$  over the whole budget (the environment’s intrinsic floor) plus whether a give-up/collision/freeze ever fired

(which brackets the unknown coefficient from below and reveals the payload class).

5. **Coverage-guided engine** (ties into TODO.md item 5). With behavioral oracle and unknown config, coverage-guided search over the failure surface is the right engine: reward candidates reaching new, lower- $C$  / deeper- $\phi$  basins, since we cannot know a priori how low or deep we must go.

**Soundness (all tiers) is one-directional.** A give-up/collision/freeze **confirms** vulnerability (one witness, sound). Bottoming out  $C$  (and depth) with no failure does **not** certify safety — report “could not trigger within budget/coverage,” never “cannot.”

---

## Why this strengthens the paper’s threat model

White-box is the strongest attacker but the weakest *claim*. Showing the attack survives with the **coefficient hidden** (gray-box) and then the **algorithm hidden** (black-box) makes the vulnerability about the *structure of myopic safe control*, not a leaked parameter or a known policy. These are exactly the tiers the intro’s threat-model TODO should enumerate. See also docs/closed\_form\_answer.pdf: the defender still cannot certify safety in closed form, while this attacker needs only one behavioral witness — the same asymmetry, now holding at progressively lower attacker knowledge.